

Política de Segurança da Informação

Exemplo autoral para estudo — não comprova implantação ou conformidade.

Identificação: PSI-NU-01 · Versão: 0.1 · Data: 08/09/2026.

Estado: proposta didática, ainda sem aprovação.

Responsável pela manutenção: responsável pelo SGSI a ser designado pela direção.

Aprovação prevista: direção da Nuvora. Vigência: após aprovação formal e comunicação.

Revisão proposta: anual ou diante de mudança relevante; esta periodicidade é uma escolha do exemplo.

1. Finalidade e abrangência

Esta política orienta a proteção das informações necessárias ao recebimento e à manutenção dos pedidos digitais e à publicação de documentos no portal. Aplica-se às pessoas, processos, instalações e recursos que sustentam esses serviços, incluindo o trabalho contratado do Suporte Norte. Abrange informações digitais, impressas ou comunicadas verbalmente nesse contexto. A relação com a operação de embalagem deverá ser esclarecida antes de ampliar o escopo do SGSI.

2. Compromissos de segurança

A Nuvora se compromete a preservar a confidencialidade, permitindo conhecimento por pessoas autorizadas; a integridade, protegendo a exatidão e as alterações legítimas; e a disponibilidade, mantendo informações e serviços acessíveis quando necessários. Compromete-se a satisfazer os requisitos de segurança aplicáveis, inclusive legais e contratuais, e a melhorar continuamente o SGSI. Esses requisitos serão identificados e mantidos atualizados.

3. Liderança e responsabilidades

A direção aprova esta política, define autoridades e disponibiliza recursos. Os gestores respondem pelos riscos e pelas necessidades de informação de seus processos. O responsável pelo SGSI coordena o acompanhamento e comunica pendências à direção. TI e prestadores executam as medidas sob sua responsabilidade. Todas as pessoas abrangidas devem conhecer as orientações pertinentes, proteger as informações utilizadas e comunicar situações suspeitas. Delegações e substituições deverão ter limites explícitos.

4. Riscos e seleção de controles

A organização avaliará os riscos com critérios definidos e comparáveis, identificará seus proprietários e decidirá o tratamento necessário. A aceitação do risco que permanecer dependerá de autoridade competente e justificativa registrada. Os controles serão selecionados conforme riscos e requisitos aplicáveis, confrontados com o Anexo A da ISO/IEC 27001:2022 e registrados na Declaração de Aplicabilidade. Mudanças relevantes exigirão reavaliação.

5. Objetivos e planejamento

A organização estabelecerá objetivos de segurança coerentes com esta política e suas necessidades de negócio, mensuráveis quando praticável. Cada objetivo terá responsável, ações, recursos, prazo e forma de avaliar resultados. Alterações no SGSI serão planejadas para preservar sua finalidade e seu funcionamento.

6. Pessoas, comunicação e documentos

As pessoas receberão orientação e preparação compatíveis com suas responsabilidades. A organização verificará as competências necessárias e a eficácia das ações de capacitação. A política será comunicada internamente e disponibilizada às partes interessadas conforme pertinente. Documentos e registros terão identificação, versão, aprovação quando cabível, proteção, acesso e conservação definidos, com prevenção do uso de versões obsoletas.

7. Proteção das informações e operação

As informações e os recursos terão responsáveis e proteção proporcional à sua importância e aos riscos. As medidas deverão considerar todo o ciclo de uso, incluindo criação, acesso, compartilhamento, armazenamento e descarte. A organização estabelecerá orientações específicas para acesso, uso de dispositivos, proteção física, configuração, mudanças, cópias de segurança e recuperação, conforme sua necessidade. A continuidade dos serviços será planejada e verificada de acordo com as prioridades do negócio.

8. Serviços contratados e mudanças

A contratação e a alteração de serviços deverão considerar os riscos à informação, as responsabilidades e os requisitos de segurança. O acesso de fornecedores será autorizado para finalidade e período definidos, acompanhado e encerrado quando deixar de ser necessário. Mudanças relevantes terão avaliação de impacto, aprovação e verificação do resultado.

9. Incidentes e exceções

A organização manterá um processo para comunicar, avaliar e responder a incidentes, preservar evidências pertinentes, recuperar o serviço e registrar lições aprendidas. Exceções às orientações de segurança dependerão de análise, justificativa, autoridade, prazo e acompanhamento. Uma exceção interna não dispensa o atendimento a obrigações aplicáveis.

10. Avaliação e melhoria

A organização acompanhará objetivos e controles, realizará auditorias internas com objetividade e imparcialidade e promoverá análises críticas pela direção em intervalos planejados. Desvios serão tratados, suas causas examinadas e a eficácia das ações corretivas verificada. Decisões sobre mudanças, recursos e oportunidades de melhoria serão registradas e acompanhadas.

Referência didática: ISO/IEC 27001:2022 e Emenda 1:2024.